

Tasklite: Security Design Document

Project: MCS 7201 - Computer Systems Security End of Semester

Version: 1.0 (Secure Rewrite)

1. Overview

Tasklite is the secure rewrite of the django.nV application. This document specifies the security controls and architectural decisions made to mitigate the risks identified during the Part A vulnerability assessment.

2. Attack Surface Analysis

The application's attack surface has been minimized through:

- Removal of unnecessary endpoints and debug features.
- Implementation of a strict Content Security Policy (CSP).
- Use of a production-grade WSGI server (Waitress) behind an Nginx reverse proxy.

3. Trust Boundaries & Data Flow

A primary trust boundary exists between the Web Browser (Untrusted) and the Django Application Logic (Trusted). All data crossing this boundary is treated as tainted and subjected to strict validation.

4. Core Security Controls

Threat Category	Implemented Control
Injection (SQL/OS)	Exclusive use of Django ORM; Elimination of shell-spawning functions (<code>os.system</code>).
Broken Access Control	Enforced <code>@login_required</code> and <code>PermissionRequiredMixin</code> on all sensitive views.
Insecure Deserialization	Disabled pickle-based sessions; switched to JSON serialization.
Sensitive Data Exposure	Argon2 for password hashing; TLS 1.3 for data in transit; HSTS enabled.
Cross-Site Scripting (XSS)	Auto-escaping template engine; Strict CSP; <code>HttpOnly/SameSite</code> cookies.
Cross-Site Request Forgery	Mandatory CSRF tokens for all state-changing (POST/PUT/DELETE) requests.

5. Deployment Hardening

- Principle of Least Privilege: The application runs as a non-root 'tasklite' user.
- File System: Uploads are stored in a non-executable directory with randomized filenames.
- Headers: X-Frame-Options set to DENY; X-Content-Type-Options set to nosniff.